Lab02

#cyber-security

1 Setup:

We first create a sample html login page in the folder of our choosing and paste within it the following sample login form:
`

Login to the system

Username:

Password:

Login

2 - Launching and Using SET (Social Engineering Toolkit):

1. We launch SET via the following command `sudo setoolkit` - Which will place us within the setoolkit console.
   Next, we choose the appropriate settings:
2. Social-Engineering Attacks (1)
3. Website Attack Vectors (2)
4. Credential Harvester Attack Method (3)
5. Custom Import (3) - You would usually use the first two options, however since we are using a local file to serve the fake website, the 3rd option is most appropriate
6. SET will processed to prompt us with the listening address (where the captured requests) should be sent, here we provide our local or loopback address.

```
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

──────────────────────────────────────────────────────────────────────────────
── * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ──

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

Enter the IP address for POST back in Harvester/Tabnabbing: 127.0.0.1
```

7. After providing the listening address, we provide the target of the cloning attack, which in this case is the location of our index.html file (SET's custom import REQUIRES an index.html exist within the target folder for cloning)
8. Additionally it will also ask for the URL for the imported website, provide any arbitrary url here.
9. Upon successfully provided inputs, SET will start serving the cloned website on port 80.

```
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/osk/Documents/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

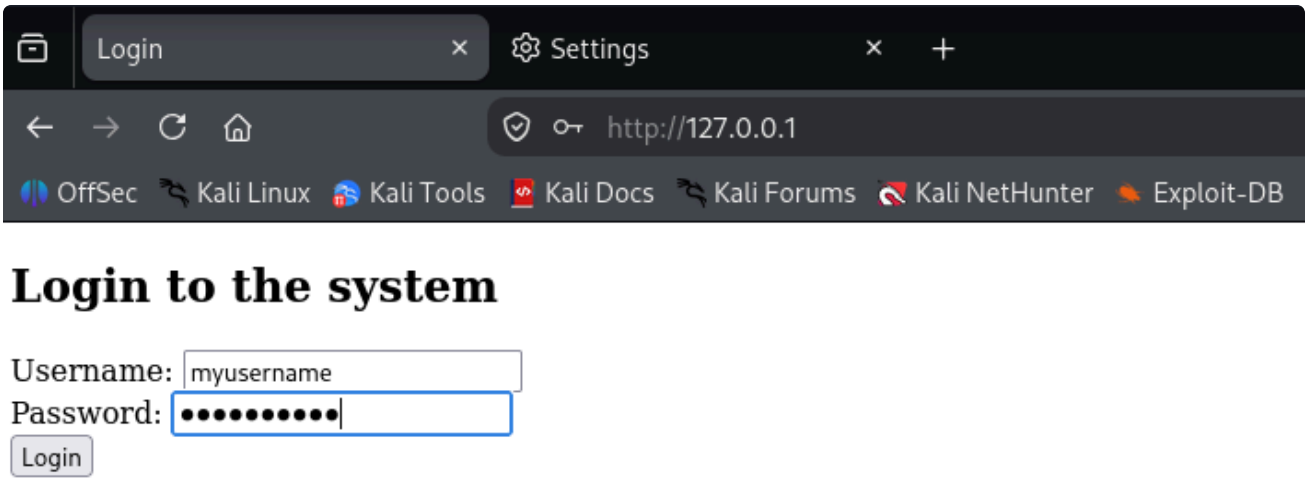
Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://legitwebsite.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

3 - Testing and Report:

We can see that SET is running properly by accessing the fake website via the browser on our local IP address. We input the following into the two fields:

- Username - myusername
- Password - mypassword
  Afterwards, we click on lo



As we can see SET has successfully captured the traffic on the cloned website, from the initial access to the captured POST request.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [24/Oct/2026 10:45:49] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=myusername
POSSIBLE PASSWORD FIELD FOUND: password=mypassword
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Final Thoughts:

1. What are the characteristics of phishing pages (e.g., a wrong URL)? - A wide range of things, ranging from lacking protocols such as serving `http` pages, invalid certificates to misspellings within it's URL of the website and domain it's trying to clone.
2. How would you protect yourself from such an attack? - Enable proper protection settings within your browser, such as strict HTTPS, not clicking phishing links, being careful of the URL and the security of the website by ensuring it has a valid certificate
3. Why do modern sites make such attacks more difficult? - More dynamic and complex making attacks such as site cloning more difficult to execute, browser protections (ranging from certificate checking to same-origin tracking etc.)